CRISC Hard Questions from ISACA QAE Manual

200 Selected Questions — Answers on the Next Page

Compiled from ISACA CRISC Review Questions, Answers & Explanations Manual, 6th Edition

October 28, 2026

Outline

1. Domain 1: Governance
2. Domain 2: IT Risk Assessment
3. Domain 3: Risk Response and Reporting
4. Domain 4: Information Technology and Security
5. Final Review

D1-Q1: Defining Risk Management Strategies

Question

Which of the following is MOST important to determine when defining risk management strategies?

A. Risk assessment criteria
B. IT architecture complexity
C. Enterprise disaster recovery plan
D. Business objectives and operations

D1-Q1: Answer

Correct Answer: D — Business objectives and operations

The risk practitioner must analyze the enterprise's objectives and risk tolerance and define a risk management framework based on this analysis. Some enterprises accept known risk; others invest in mitigating controls. Risk assessment criteria alone are insufficient; IT complexity relates to assessment, not strategy; a DR plan relates to mitigation.

D1-Q2: Risk Management Strategic Plan

Question

Which of the following is the MOST important information to include in a risk management strategic plan?

A. Risk management staffing requirements
B. Risk management mission statement
C. Risk mitigation investment plans
D. Current state and desired future state

D1-Q2: Answer

Correct Answer: D — Current state and desired future state

It is most important to paint a vision for the future and draw a road map from the starting point, which requires that the current state and desired future state be fully understood. Staffing, mission, and investment plans are generally driven by that understanding.

D1-Q3: Business Unit Risk Roles

Question

Which BEST describes the risk-related roles of an organizational business unit (BU)? The BU management team:

A. Owns the mitigation plan while board members identify and assess risk

B. Owns the risk and is responsible for identifying, assessing, mitigating, and reporting

C. Carries out risk responsibilities, but ultimate accountability belongs to the board

D. Is ultimately accountable, and the board owns the risk

D1-Q3: Answer

Correct Answer: B

The BU is responsible for owning the risk and its resulting actions. Risk owners identify, measure, monitor, control, and report on risk to executive management as established by the corporate risk framework. The board does not perform risk identification or assessment functions.

D1-Q4: Outsourced IT in Foreign Country

Question

An enterprise has outsourced the majority of its IT department to a third party whose servers are in a foreign country. Which is the MOST critical security consideration?

- A Security breach notification may be delayed due to the time difference
- B Additional network intrusion detection sensors are required
- C The enterprise could be unable to monitor compliance with internal security and privacy guidelines
- D Laws and regulations of the country of origin may not be enforceable in the foreign country

D1-Q4: Answer

Correct Answer: D

Laws and regulations of the country of origin may not be enforceable in the foreign country. Conversely, the laws of the foreign vendor may affect the enterprise. Potential violation of local laws may not be recognized or remedied due to lack of knowledge and/or inability to enforce.

D1-Q5: Improving Risk Management Process

Question

Which of the following is MOST beneficial to improvement of an enterprise's risk management process?

A. Key risk indicators
B. External benchmarking
C. Latest risk assessment
D. A maturity model

D1-Q5: Answer

Correct Answer: D — A maturity model

A maturity model helps identify the status quo and the path to the desired state and is most helpful when an enterprise desires to improve a business process such as risk management. KRIs and benchmarking do not define the desired state; the latest risk assessment is only an input.

D1-Q6: Independent Risk Review

Question

Which is the PRIMARY reason for subjecting the risk management process to review by independent risk auditors and assessors?

A. To ensure that the risk results are consistent
B. To ensure that the risk factors and risk profile are well-defined
C. To correct any mistakes in risk assessment
D. To validate the control weaknesses for management reporting

D1-Q6: Answer

Correct Answer: B

Risk profile and risk factors are defined during the risk assessment process; an independent review helps ensure that the underlying process is effective and helps identify areas for future improvement.

D1-Q7: Evaluating Legal/Regulatory Impact

Question

What is the MOST effective method to evaluate the potential impact of legal, regulatory, and contractual requirements on business objectives?

A. A compliance-oriented gap analysis

B. Interviews with business process stakeholders

C. A mapping of compliance requirements to policies and procedures

D. A compliance-oriented business impact analysis

D1-Q7: Answer

Correct Answer: D

A compliance-oriented BIA identifies compliance requirements to which the enterprise is subject and assesses their effect on business objectives and activities. Gap analysis only finds gaps; interviews identify objectives but not compliance; mapping shows how compliance is achieved but not business impact.

D1-Q8: Maturity Assessment RFP

Question

An enterprise is hiring a consultant to determine the maturity level of the risk management program. The MOST important element of the RFP is the:

- A Sample deliverable
- B Past experience of the engagement team
- C Methodology used in the assessment
- D References from other enterprises

D1-Q8: Answer

Correct Answer: C — Methodology

Methodology illustrates the consultant's process and offers a basis to align expectations with execution of the assessment. It establishes requirements of all parties involved.

D1-Q9: New Law Affecting HR System

Question

Shortly after the annual policy review, a risk practitioner becomes aware that a new law may affect security requirements for the HR system. The risk practitioner should:

A. Analyze what systems and technology-related processes may be impacted

B. Ensure necessary adjustments are implemented during the next review cycle

C. Initiate an ad hoc revision of the corporate policy

D. Notify the system custodian to implement changes

D1-Q9: Answer

Correct Answer: A

Assessing what systems and technology-related processes may be impacted is the best course of action. The analysis must also determine whether existing controls already address the new requirements. Policy changes require proper approval; waiting can create compliance risk.

D1-Q10: Outsourced Data Processing Violation

Question

An enterprise outsourced personnel data processing to a supplier, and a regulatory violation occurs during processing. Who will be held legally responsible?

A. The supplier, because it has operational responsibility
B. The enterprise, because it owns the data
C. The enterprise and the supplier
D. The supplier, because it did not comply with the contract

D1-Q10: Answer

Correct Answer: B

The enterprise retains responsibility for management of and adherence to policies, procedures, and regulatory requirements. The regulatory authority will generally hold the enterprise responsible for failure to comply, including penalties. Supplier responsibility is limited to contract terms.

D1-Q11: Evaluating Internal Controls Effectiveness

Question

Which role is responsible for evaluating the effectiveness of existing internal information security controls within an enterprise?

A. Data owner
B. Senior management
C. End users
D. System auditor

D1-Q11: Answer

Correct Answer: D — System auditor

The system auditor provides continuous feedback to senior management about the effectiveness of internal controls. Data owners define requirements; senior management ensures effectiveness; end users are not responsible for evaluation.

D1-Q12: Overall Effectiveness of Risk Program

Question

Which of the following BEST ensures the overall effectiveness of a risk management program?

A. Obtaining feedback from all end users
B. Assigning a dedicated risk manager to run the program
C. Applying quantitative risk methodologies
D. Gaining the participation of relevant stakeholders

D1-Q12: Answer

Correct Answer: D

Without participation from enterprise stakeholders and their active role in supervision and risk monitoring, the effectiveness of a risk management program cannot be guaranteed. All-user feedback is infeasible; a dedicated manager without stakeholders is less effective; methodology choice depends on needs.

D1-Q13: Achieving Risk-Based Objectives

Question

Which approach BEST helps an enterprise achieve risk-based organizational objectives?

A. Ensure that asset owners perform annual risk assessments
B. Review and update the risk register regularly
C. Assign a steering committee to the risk management process
D. Embed risk management activities into business processes

D1-Q13: Answer

Correct Answer: D

The primary objective of embedding risk management activities into business processes is to achieve risk-based organizational objectives in the most effective manner possible. Assessments alone, register maintenance, or a steering committee are less effective.

D1-Q14: Regulatory Reliance on Reviews

Question

When assessing the capability of the risk management process, a regulatory body would place the GREATEST reliance on:

A. A peer review
B. An internal review
C. An external review
D. A process capability review

D1-Q14: Answer

Correct Answer: C — External review

Regulatory entities generally use assessments performed by an objective and independent third party. An external review is the most objective and independent of the choices presented.

D1-Q15: Evaluating Current Risk Profile

Question

A company has been improving its security and compliance program since the last review one year ago. What should it do to evaluate its current risk profile?

- A Review previous findings and ensure all issues are resolved
- B Conduct follow-up audits in previously deficient areas
- C Monitor KRIs and use results to develop targeted assessments
- D Perform a new enterprise risk assessment using an independent expert

D1-Q15: Answer

Correct Answer: D

The best way to ensure the security posture is still compliant is to conduct another risk assessment. A lot can change in a year, and an independent expert provides more objective results than internal staff testing their own work.

D1-Q16: Inadequate Data/System Ownership Policy

Question

Which is the GREATEST risk of a policy that defines data and system ownership inadequately?

A. Audit recommendations may not be implemented
B. Users may have unauthorized access to create, modify, or delete data
C. User management coordination does not exist
D. Specific user accountability cannot be established

D1-Q16: Answer

Correct Answer: B

Without a policy defining who grants access to specific data or systems, the risk that employees receive access without justified business purpose increases. Authority to grant access should be assigned to specific individuals.

D1-Q17: Management's Role in Risk Strategy

Question

Which BEST describes the role of management in implementing a risk management strategy?

A. Ensure that planning, budgeting, and performance of security components are appropriate

B. Assess and incorporate the results of risk management into decision-making

C. Identify, evaluate, and minimize risk to IT systems supporting the mission

D. Understand the risk management process to develop training materials

D1-Q17: Answer

Correct Answer: B

Assessing and incorporating the results of risk management into the decision-making process best describes the role of senior management in establishing and implementing a risk management strategy.

D1-Q18: Primary Focus of IT Business Risk

Question

The PRIMARY focus of managing IT-related business risk is to protect:

A. Information
B. Hardware
C. Applications
D. Databases

D1-Q18: Answer

Correct Answer: A — Information

The primary objective for any enterprise is to protect mission-critical information based on a risk assessment. Hardware, applications, and databases are focuses only if they store, process, or transfer mission-critical data.

D1-Q19: Best Risk Management Perspective

Question

Which can provide the BEST perspective of risk management to an enterprise's employees and stockholders?

- (A) An interdisciplinary team within the enterprise
- (B) A third-party risk assessment service provider
- (C) The enterprise's IT department
- (D) The enterprise's internal compliance department

D1-Q19: Answer

Correct Answer: A

An interdisciplinary team ensures all areas are adequately considered in risk assessment and provides an enterprise-wide perspective. Third parties lack internal knowledge; IT alone does not reflect the enterprise; compliance focuses on regulatory implications.

D1-Q20: Global Policy for Multiple Regions

Question

Which approach to corporate policy BEST supports an enterprise's expansion to other regions where different local laws apply?

- A. A global policy without provisions that might be disputed locally
- B. A global policy amended to comply with local laws
- C. A global policy that complies with laws at enterprise headquarters
- D. Local policies to accommodate laws within each region

D1-Q20: Answer

Correct Answer: B

A global policy including local amendments ensures alignment with local laws and regulations. A single global policy cannot address all locales; HQ-only policy exposes legal risk; decentralized local policies are expensive and fail to leverage common practices.

D1-Q21: Data Classification Responsibility

Question

Who is MOST likely responsible for data classification?

A. Data user
B. Data owner
C. Data custodian
D. System administrator

D1-Q21: Answer

Correct Answer: B — Data owner

The data owner classifies data according to the enterprise's data classification scheme. The classification defines who is eligible to access the data and what controls are required. Custodians implement custody and storage.

D1-Q22: Security Governance Model Impact

Question

Which factor will have the GREATEST impact on the type of information security governance model an enterprise adopts?

A. The number of employees
B. The enterprise's budget
C. The organizational structure
D. The type of technology used

D1-Q22: Answer

Correct Answer: C — Organizational structure

Information security governance models depend significantly on the overall organizational structure. Employee count, budget, and technology do not primarily drive the governance model; well-defined processes provide proper governance.

D1-Q23: Information Security Procedures

Question

Information security procedures should:

A. Be updated frequently as new software is released
B. Underline the importance of security governance
C. Define the allowable limits of behavior
D. Describe security baselines for each platform

D1-Q23: Answer

Correct Answer: A

Security procedures must change frequently to keep up with software changes. Because a procedure is a how-to document, it must be kept current. Governance is addressed in policy; behavioral limits are set by policy; baselines are set by standards.

D1-Q24: Greatest Benefit of Risk-Aware Culture

Question

Which is the GREATEST benefit of a risk-aware culture?

- A Issues are escalated when suspicious activity is noticed
- B Controls are double-checked to anticipate any issues
- C Individuals communicate with peers for knowledge sharing
- D Employees are self-motivated to learn about costs and benefits

D1-Q24: Answer

Correct Answer: A

Management benefits most from an escalation process because risk and incidents are reported in a timely manner. Escalation posture among employees is best developed through training and awareness programs.

D1-Q25: Main Objective of IT Risk Management

Question

The MAIN objective of IT risk management is to:

A. Prevent loss of IT assets
B. Provide timely management reports
C. Ensure regulatory compliance
D. Enable risk-aware business decisions

D1-Q25: Answer

Correct Answer: D

IT risk management should be conducted as part of enterprise-wide risk management, whose ultimate objective is to support risk-aware business decisions. Asset protection, timely reporting, and compliance are subordinate goals.

D1-Q26: Multiple Governmental Jurisdictions

Question

Which is the BEST approach for a global enterprise subject to regulation by multiple governmental jurisdictions with differing requirements?

- (A) Bring all locations into conformity with the aggregate requirements of all jurisdictions
- (B) Bring all locations into conformity with generally accepted industry good practices
- (C) Establish a baseline standard incorporating the requirements all jurisdictions have in common
- (D) Establish baseline standards for all locations and add supplemental standards as required

D1-Q26: Answer

Correct Answer: D

It is more efficient to establish a baseline standard and then develop additional standards for locations that must meet specific requirements. Aggregate conformity places undue burden; good practices may not meet compliance; lowest common denominator risks noncompliance.

D1-Q27: Final Sign-off on Risk Plan

Question

Who MUST give final sign-off on the IT risk management plan?

- A IT auditors performing the risk assessment
- B Business process owners
- C Senior managers
- D IT security administrators

D1-Q27: Answer

Correct Answer: C — Senior managers

Senior managers understand performance metrics, approved the policies and standards that govern the enterprise, and have final responsibility for risk associated with audit findings and recommendations.

D1-Q28: Security Boundary Before Assessment

Question

Which is the PRIMARY reason a risk practitioner determines the security boundary prior to conducting a risk assessment?

A. To decide which laws and regulations apply
B. To identify the scope of the risk assessment
C. To identify the business owners of the system
D. To decide whether quantitative or qualitative analysis is appropriate

D1-Q28: Answer

Correct Answer: B — Identify the scope

Identifying the security boundary establishes the fundamental scope of inquiry, including which systems and components are subject to assessment. The boundary subsequently informs which laws apply and which business owners to consult.

D1-Q29: Who Manages/Executes Risk Program

Question

Which group would be MOST effective in managing and executing an enterprise's risk program?

A. Mid-level managers
B. Senior managers
C. Frontline employees
D. The incident response team

D1-Q29: Answer

Correct Answer: A — Mid-level managers

Mid-level managers are most centrally located within the organizational hierarchy, combining sufficient breadth of influence with proximity to day-to-day operations. Senior managers sponsor but are too high to manage; frontline employees lack influence.

D1-Q30: IT Steering Committee Representation

Question

The IT steering committee of a one-year-old start-up makes all IT decisions, including technology budget. It will be BEST represented by:

A. Members of the executive board
B. High-level members of the IT department
C. IT experts from outside the enterprise
D. Key members from each department

D1-Q30: Answer

Correct Answer: D

The IT steering committee should be comprised of individuals from each department to ensure the entire enterprise is represented and all business objectives are more likely to be met.

D1-Q31: First Line of Defense Purpose

Question

Which is one of the MAIN purposes of the first line of defense in the three lines of defense model?

- A Ensure that financial controls are in place
- B Ensure control deficiencies are addressed
- C Ensure risk management practices are effective
- D Ensure compliance with rules and regulations

D1-Q31: Answer

Correct Answer: B

In the first line, operational managers own the risk and address it by mitigating control deficiencies. Risk management is part of the second line; ensuring compliance is part of the second line.

D1-Q32: Selecting Risk Response Technique

Question

The PRIMARY consideration when selecting a risk response technique is:

A. Coverage of all identified risk
B. Availability of resources
C. Enterprise goals and objectives
D. Standards and industry good practices

D1-Q32: Answer

Correct Answer: C

The risk response will be based primarily on the goals and objectives of the enterprise. Risk can harm these goals and must be mitigated according to priority. Standards and good practices are followed after the technique is selected.

D1-Q33: First Policy for Start-up

Question

The board of a one-year-old start-up asked the CIO to create all IT policies and procedures. Which should the CIO create FIRST?

A. The strategic IT plan
B. The data classification scheme
C. The information architecture document
D. The technology infrastructure plan

D1-Q33: Answer

Correct Answer: A — Strategic IT plan

The strategic IT plan is the first policy to create when developing an enterprise's governance model. Data classification, information architecture, and technology infrastructure plan are created afterward.

D1-Q34: Most Concerning to Risk Practitioner

Question

Which should be of MOST concern to a risk practitioner?

- A Failure to notify the public of an intrusion
- B Failure to notify the police of an attempted intrusion
- C Failure to internally report a successful attack
- D Failure to examine access rights periodically

D1-Q34: Answer

Correct Answer: C

Failure to report a successful intrusion is a serious concern and could in some instances be interpreted as abetting. Public notification is not a requirement; attempted intrusions rarely require police notification.

D1-Q35: Insight into Risk Capabilities

Question

Which review will provide the MOST insight into an enterprise's risk management capabilities?

A. A capability maturity model review
B. A capability comparison with industry standards or regulations
C. A self-assessment of capabilities
D. An internal audit review of capabilities

D1-Q35: Answer

Correct Answer: A

Capability maturity modeling allows an enterprise to understand its level of maturity in its risk capabilities, which is an indicator of operational readiness and effectiveness. The other options indicate existence or non-existence only.

D1-Q36: Leveraging Internal Audit in ERM

Question

As part of an ERM program, a risk practitioner BEST leverages the work performed by internal audit by having it:

A. Design, implement, and maintain the ERM process

B. Manage and assess the overall risk awareness

C. Evaluate ongoing changes to enterprise risk factors

D. Assist in monitoring, evaluating, examining, and reporting on controls

D1-Q36: Answer

Correct Answer: D

The internal audit function is responsible for assisting management and the board in monitoring, evaluating, examining, and reporting on internal controls, regardless of whether an ERM function has been implemented.

D1-Q37: Interconnections with External Systems

Question

Which is the BIGGEST concern for a CISO regarding interconnections with systems outside the enterprise?

A. Requirements to comply with each other's contractual security obligations

B. Uncertainty that the other system will be available as needed

C. The ability to perform risk assessments on the other system

D. Ensuring communications are encrypted through a VPN tunnel

D1-Q37: Answer

Correct Answer: A

Ensuring both systems comply with mutual contractual security obligations should be the primary concern. If one system fails to comply, both will likely miss their respective security obligations.

D1-Q38: IT Organizational Structure

Question

The CIO creates all IT policies and procedures, managed and approved by the IT steering committee, which makes all IT decisions including the technology budget. Which type of IT organizational structure is this?

- A Project-based
- B Centralized
- C Decentralized
- D Divisional

D1-Q38: Answer

Correct Answer: B — Centralized

Within a centralized IT organizational structure, one group makes all decisions for the entire enterprise.

D1-Q39: Communicating Continuous Monitoring

Question

The aggregated results of continuous monitoring activities are BEST communicated to:

A. The risk owner
B. Technical staff
C. The audit department
D. The information security manager

D1-Q39: Answer

Correct Answer: A — The risk owner

The risk owner is accountable for the fact that appropriate risk responses are executed in alignment with the enterprise's risk appetite. Technical staff benefit from granular data; audit and security managers are secondary audiences.

D1-Q40: IT Risk Awareness Program

Question

Which is a PRIMARY consideration when developing an IT risk awareness program?

A. Why technology risk is owned by IT
B. How technology risk can affect each attendee's area of business
C. How business process owners can transfer technology risk
D. Why technology risk is more difficult to manage than other risk

D1-Q40: Answer

Correct Answer: B

Stakeholders must understand how IT-related risk affects the overall business and how potential threats and vulnerabilities can jeopardize the enterprise's people, processes, and technology. IT does not own technology risk.

D1-Q41: IT Delivering Against Requirements

Question

Management wants to ensure IT is successful in delivering against business requirements. Which BEST supports that effort?

A. An internal control system or framework
B. A cost-benefit analysis
C. A return on investment analysis
D. A benchmark process

D1-Q41: Answer

Correct Answer: A

For IT to be successful in delivering against business requirements, management should develop an internal control system that supports its business requirements. Cost-benefit and ROI are metrics; benchmarking comes after a sound control framework.

D1-Q42: Aligning Risk Appetite

Question

It is MOST important that risk appetite be aligned with business objectives to ensure that:

A. Resources are directed toward areas of low risk tolerance
B. Major risk is identified and eliminated
C. IT and business goals are aligned
D. The risk strategy is adequately communicated

D1-Q42: Answer

Correct Answer: A

Aligning risk appetite with business objectives allows an enterprise to evaluate and deploy valuable resources toward those objectives with low risk tolerance for loss. Risk cannot be eliminated; alignment is broader than IT/business; communication does not depend on alignment.

D1-Q43: Out-of-Date Security Policy

Question

Which causes the GREATEST concern to a risk practitioner reviewing a corporate information security policy that is out of date? The policy:

A. Was not reviewed within the last three years
B. Is missing newer technologies/platforms
C. Was not updated to account for new locations
D. Does not enforce control monitoring

D1-Q43: Answer

Correct Answer: A

Not reviewing the policy for three years and updating it as necessary does not follow good practices and is the greatest concern. Policies are written at a level that does not require modification for specific technologies or locations.

D1-Q44: Accountable for IT Business Risk

Question

Who is accountable for business risk related to IT?

- (A) Chief information officer
- (B) Chief financial officer
- (C) Users of IT services
- (D) Chief architect

D1-Q44: Answer

Correct Answer: C — Users of IT services

The enterprise (i.e., the users of IT services) ultimately owns business-related risk, including the risk related to the use of IT. The business sets the mandate, provides resources, and monitors whether risk is being managed.

D1-Q45: Expanding to Nearby Domestic Locations

Question

An enterprise is expanding into new nearby domestic locations. Which is MOST important for a risk practitioner to report on?

A. Competitor analysis
B. Legal and regulatory requirements
C. Political issues
D. Potential of natural disasters

D1-Q45: Answer

Correct Answer: B

Legal and regulatory requirements are most likely to change when moving to a nearby location because each municipality may enforce significantly different regulations, including environmental requirements, taxation, and others.

D1-Q46: True Statement About IT Risk

Question

Which of the following is true about IT risk?

- (A) IT risk cannot be assessed and measured quantitatively
- (B) IT risk should be calculated separately from business risk
- (C) IT risk management is the responsibility of the IT department
- (D) IT risk exists regardless of whether it is detected or recognized

D1-Q46: Answer

Correct Answer: D

The enterprise must identify, acknowledge, and respond to risk; ignorance of risk is not acceptable. IT risk can be measured both quantitatively and qualitatively; it is one type of business risk; and it is the responsibility of senior management.

D1-Q47: Selecting Risk Management Methodology

Question

Which is MOST important when selecting an appropriate risk management methodology?

A. Risk culture
B. Countermeasure analysis
C. Cost-benefit analysis
D. Risk transfer strategy

D1-Q47: Answer

Correct Answer: A — Risk culture

Without understanding risk culture—how and why an enterprise makes decisions regarding risk—one cannot select a risk management methodology. Countermeasure and cost-benefit analysis target specific controls; not all risk can be transferred.

D1-Q48: Compliance with Risk Appetite

Question

Which BEST determines compliance with the risk appetite of an enterprise?

A. Balance between preventive and detective controls
B. Inherent risk and acceptable risk level
C. Residual risk and acceptable risk level
D. Balance between countermeasures to threats and preventive controls

D1-Q48: Answer

Correct Answer: C

Considering residual risk in terms of acceptable risk yields risk that is appropriately balanced after the application of controls. Management can then decide to accept risk or apply additional controls.

D1-Q49: Monitoring Control Effectiveness vs External Requirements

Question

A key objective when monitoring information systems control effectiveness against the enterprise's external requirements is to:

A. Design the applicable information security controls for external audits
B. Create the enterprise's information security policy provisions for third parties
C. Ensure that the enterprise's legal obligations have been satisfied
D. Identify those legal obligations that apply to the enterprise's security practices

D1-Q49: Answer

Correct Answer: C

Legal obligations are one of the principal external requirements that necessitate compliance monitoring. Control design occurs in risk treatment; policy creation occurs well before monitoring; obligations are identified before treatment.

D1-Q50: Overall Risk Status

Question

Risk monitoring provides timely information on the actual status of the enterprise with regard to risk. Which choice provides an overall risk status of the enterprise?

A. Risk management
B. Risk analysis
C. Risk appetite
D. Risk profile

D1-Q50: Answer

Correct Answer: D — Risk profile

The risk profile provides the current overall portfolio of identified risk to which the enterprise is exposed. Because the profile is updated with evolving and new risk, it provides the enterprise's current risk status.

D1-Q51: Firewall Deviation from Security Policy

Question

Which activity should a risk professional perform to determine whether firewall deployments are deviating from the enterprise's information security policy?

- A Review the firewall parameter settings
- B Review the firewall intrusion prevention system logs
- C Review the firewall hardening procedures
- D Analyze the firewall log file for recent attacks

D1-Q51: Answer

Correct Answer: A

Firewall parameter settings tie into configurations linked to the governing security policy. If parameter settings differ from what policy states or requires, there is a deviation.

D1-Q52: Continuous Risk Management Benefit

Question

Which is the MOST significant benefit of implementing a continuous risk management process in an enterprise?

A. It complies with external regulators' requirements
B. It captures changes to the enterprise's risk profile
C. It ensures stakeholders are linked to the identified risk
D. It ensures timely action is taken to mitigate risk

D1-Q52: Answer

Correct Answer: B

A continuous risk management process ensures changes to the enterprise's risk profile are captured. The other choices are secondary or inaccurate.

D1-Q53: High Risk vs Moderate Appetite

Question

Senior management defined the enterprise risk appetite as moderate. A business-critical application poses a high risk. What is the NEXT action?

A. Remove the high-risk application and replace it with another system
B. Recommend that management increase its acceptable risk level
C. Assess the impact of planned controls to the application
D. Restrict access to the application only to trusted users

D1-Q53: Answer

Correct Answer: C

The risk practitioner should determine whether planned implementation of new controls may lower the risk from high to moderate or low before taking further action. Removing the app risks downtime; recommending a tolerance increase is the business owner's call.

D1-Q54: Developing the Risk Profile

Question

Which BEST assists in the development of the risk profile?

A. The presence of preventive and detective controls
B. Inherent risk and detection risk
C. Cost-benefit analysis of controls
D. Likelihood and impact of risk

D1-Q54: Answer

Correct Answer: D

Likelihood and impact of risk help in the development of the risk profile. Controls alone, inherent/detection risk, and cost-benefit analysis do not develop the profile itself.

D1-Q55: Employee Handbook in Multiple Regions

Question

An enterprise expanded into Europe, Asia, and Latin America and has a single-version, multiple-language handbook last updated three years ago. Which is of MOST concern?

A. The handbook may not have been correctly translated
B. Newer policies may not be included
C. Expired policies may be included
D. The handbook may violate local laws and regulations

D1-Q55: Answer

Correct Answer: D

Because customs and laws affect an enterprise's ability to operate in a location and vary by state and country, it is critical for the employee handbook to acknowledge and account for regional and national differences.

D2-Q56: Annual Loss Expectancy Formula

Question

An asset's annual loss expectancy is calculated as the:

A. Exposure factor (EF) multiplied by the annualized rate of occurrence (ARO)

B. Single loss expectancy (SLE) multiplied by the EF

C. SLE multiplied by the ARO

D. Asset value multiplied by the SLE

D2-Q56: Answer

Correct Answer: C — ALE = SLE × ARO

ALE is calculated by multiplying the single loss expectancy (SLE) by the annualized rate of occurrence (ARO), the number of times the enterprise expects the loss to occur.

D2-Q57: Effective Information Risk Program

Question

Which is the BEST indicator of an effective information risk management program?

A. The security policy is made widely available
B. Risk is considered before all decisions
C. Security procedures are updated annually
D. Risk assessments occur on an annual basis

D2-Q57: Answer

Correct Answer: B

Defining information risk in advance of business decisions best ensures that risk tolerance remains at approved levels. Policy availability, annual procedures updates, and annual assessments facilitate but are not as critical.

D2-Q58: Risk Management Strategic Plans

Question

Risk management strategic plans are MOST effective when developed for:

A. The enterprise as a whole
B. Each individual system based on technology used
C. Every location based on geographic threats
D. End-to-end business processes

D2-Q58: Answer

Correct Answer: A

Risk management strategic plans are most effective when they are created and followed by the entire enterprise. Per-technology, per-location, or per-process plans create complexity and conflicting policies.

D2-Q59: Considering Risk Appetite

Question

Which is MOST important when considering the risk appetite of an enterprise?

A. The capacity of the enterprise to absorb loss
B. The definition of responsibilities for risk management
C. The line of business and the typical risk of the industry
D. The culture and predisposition toward risk taking

D2-Q59: Answer

Correct Answer: D

When considering risk appetite, two major factors are relevant: the management culture and the predisposition toward risk taking. Capacity to absorb loss is important but does not influence appetite as much as culture.

D2-Q60: Primary Purpose of ERM Framework

Question

The PRIMARY purpose of adopting an enterprise-wide risk management framework is to:

A. Allow flexibility to adjust the risk response strategy

B. Centralize responsibility for the maintenance of the risk response program

C. Enable a consistent approach to risk response throughout the enterprise

D. Avoid higher costs for risk reduction and audit strategies

D2-Q60: Answer

Correct Answer: C

Enabling consistent risk response is a key objective of the risk management framework. Risk management is the responsibility of all individuals; accountability lies with senior management and the board.

D2-Q61: 15% Project Deviation

Question

Projects frequently exceed timelines or budget by nearly 10 percent; management advises a deviation of 15 percent is acceptable. This is an example of:

- A Risk avoidance
- B Risk tolerance
- C Risk acceptance
- D Risk mitigation

D2-Q61: Answer

Correct Answer: B — Risk tolerance

Risk tolerance is the permissible deviation from declared risk appetite levels. Avoidance steers clear of the activity; acceptance is a decision not to act; mitigation manages risk through countermeasures.

D2-Q62: Computing Annual Loss Exposure

Question

Which is MOST useful when computing annual loss exposure?

A. The cost of existing controls
B. The number of vulnerabilities
C. The net present value of the asset
D. The business value of the asset

D2-Q62: Answer

Correct Answer: D

Annual loss exposure is a function of the value of the information asset and the impact if a given potential risk should materialize. Control cost, vulnerability count, and NPV do not directly determine loss exposure.

D2-Q63: GRC Tool Major Risk

Question

Which is a MAJOR risk associated with the use of governance, risk, and compliance (GRC) tools?

A. Misinterpretation of the dashboard's output
B. Incomplete or inaccurate coverage in the enterprise for GRC
C. Obsolescence of content
D. Complex integration of diverse requirements

D2-Q63: Answer

Correct Answer: C — Obsolescence of content

A GRC application must be updated regularly with current regulations and policies. Obsolete content renders a GRC outdated. The technology team should refresh the unified compliance framework (UCF) file quarterly and implement processes to address changes.

D2-Q64: Need to Review Risk Practices

Question

Which signifies the need to review an enterprise's risk practices?

A. Business owners regularly challenge risk assessment findings
B. Manufacturing assigns its own internal risk management roles
C. The finance department finds exceptions during its yearly risk review
D. Sales department risk procedures were last reviewed 11 months ago

D2-Q64: Answer

Correct Answer: A

An enterprise's risk management practices must be clearly understood and supported by business stakeholders. Business owners challenging risk assessment findings either do not support or do not understand them clearly.

D2-Q65: Correct Info Not Received in Time

Question

The correct information was not received by the necessary recipients in a suitable time to allow proper action. This can be categorized as:

A. Integrity risk
B. Availability risk
C. Access risk
D. Relevance risk

D2-Q65: Answer

Correct Answer: D — Relevance risk

Relevance risk is a composite form of business risk, requiring both integrity and availability to be addressed. Transmitting information to the necessary recipients in a timely manner also creates tension with access (security) risk.

D2-Q66: Justifying Security Program

Question

Which risk assessment output is MOST suitable to help justify an enterprise information security program?

A. An inventory of risk that may impact the enterprise
B. Documented threats to the enterprise
C. Evaluation of the consequences
D. A list of appropriate controls for addressing risk

D2-Q66: Answer

Correct Answer: D

A list of information security controls corresponding to risk scenarios is one of the primary deliverables of the risk assessment exercise. It demonstrates due consideration of risk and applicable controls to address the risk.

D2-Q67: Ultimate Accountability for Risk

Question

Accountability for risk ultimately belongs to the:

A. Chief risk officer
B. Compliance officer
C. Chief financial officer
D. Board of directors

D2-Q67: Answer

Correct Answer: D — Board of directors

The board of directors has ultimate accountability to shareholders, customers, employees, and the general public. The CRO, compliance officer, and CFO have responsibilities but are not ultimately accountable.

D2-Q68: Outdated IT Standards

Question

A risk assessment reveals that many corporate IT standards have not been updated. The BEST course of action is to:

A. Review the standards against current requirements and determine their adequacy

B. Determine that the standards should be updated annually

C. Report that IT standards are adequate and do not need updating

D. Review the IT policy document to see how frequently standards should be updated

D2-Q68: Answer

Correct Answer: A

The risk practitioner should verify that the standards are still adequate; standards that are lacking should be updated. The other options do not determine adequacy or relevance.

D2-Q69: Accountable for Third-Party App Risk

Question

Marketing procures a third-party application found to pose data privacy regulatory risk in some regions. Who will be accountable for the risk if implemented globally?

- A The IT department
- B The data privacy officer
- C The chief risk officer
- D The marketing department

D2-Q69: Answer

Correct Answer: D — Marketing department

Marketing is the business owner of the application and therefore must be accountable. According to COBIT, accountability rests with those who own the required resources and have authority to approve the execution and accept the outcome.

D2-Q70: Owns Risk Treatment Decisions

Question

A risk practitioner is conducting a risk assessment of the local office's network infrastructure. Who owns the risk treatment decisions?

- A Control owner
- B Chief information officer
- C IT security manager
- D Senior management

D2-Q70: Answer

Correct Answer: D — Senior management

Senior management ultimately owns the risk and would make risk treatment decisions. The control owner, CIO alone, and IT security manager do not own the business risk.

D2-Q71: Responsible for Third-Party App Risk

Question

Marketing procures a third-party application that poses data privacy regulatory risk. Which role will be responsible for the risk it poses to the business if implemented globally?

- A The marketing department
- B The IT department
- C The data privacy officer
- D The chief risk officer

D2-Q71: Answer

Correct Answer: B — IT department

The IT department is responsible for the risk posed by this application. IT policy states that no tool or application can be implemented within production without a risk assessment and mitigation of all risk to an acceptable level.

D2-Q72: Supporting Encryption Recommendation

Question

Which provides the GREATEST support to a risk practitioner recommending encryption of corporate laptops and removable media as a risk mitigation measure?

A. Benchmarking with peers
B. Evaluating public reports on encryption algorithms
C. Developing a business case
D. Scanning unencrypted systems for vulnerabilities

D2-Q72: Answer

Correct Answer: C — Developing a business case

A business case documents how encryption addresses risk and illustrates that risk losses can be reduced by recommended controls. Peers have different environments; public reports are generic; scanning unencrypted systems without justification does not support the recommendation.

D2-Q73: Additional Stakeholder for Privacy Risk

Question

Marketing procures a third-party application that poses data privacy regulatory risk in certain regions. Which additional stakeholder should be included in reporting the risk?

- A Chief privacy officer
- B Third-party vendor
- C Business continuity manager
- D Audit manager

D2-Q73: Answer

Correct Answer: A — Chief privacy officer

The chief privacy officer supports defining controls that will be implemented to address and mitigate data transfer and data privacy requirements. If the application must be used, the CPO becomes a critical stakeholder who must be informed.

D2-Q74: Cloud Email Retention Contract

Question

A company learned its cloud email provider was never contracted to back up messages, despite a three-year retention policy. Which would have BEST safeguarded the company?

- A Providing the contractor with the record retention policy up front
- B Validating the company policies to the provider's contract
- C Providing the contractor with the email retention policy up front
- D Backing up the data on the company's internal network nightly

D2-Q74: Answer

Correct Answer: B

The initial review of third-party services should confirm that vendors are contractually required to enforce all internal policies, including record retention. Providing policies does not legally bind the third party.

D2-Q75: No Policy for Personal Devices

Question

If an enterprise does not have a formal policy regarding personal devices in the workplace, which should the risk practitioner recommend?

A. Introduce remote wipe functionality
B. Implement an exception process based on appropriate approvals
C. Update incident response procedures
D. Create and maintain an inventory of personal devices

D2-Q75: Answer

Correct Answer: B

If employees can attach personal devices without a formal policy, employees should be required to gain approval from management, documented and reviewed in a security exception form based on the exception process.

D2-Q76: Applying Risk Management

Question

To be effective, risk management should be applied to:

A. The elements identified by a risk assessment
B. Any area that exceeds acceptable risk levels
C. All enterprise activities
D. Only those areas that have potential impact

D2-Q76: Answer

Correct Answer: C

Although not all enterprise activities entail unacceptable risk, the practice of risk management is ideally applied to all enterprise activities. Risk management must be holistic, not limited to areas that exceed acceptable levels.

D2-Q77: Basis for Corporate Security Policy

Question

Development of corporate information security policy should PRIMARILY be based on:

A. Vulnerabilities
B. Threats
C. Assets
D. Impacts

D2-Q77: Answer

Correct Answer: C — Assets

The corporate information security policy is based on management's commitment to protect the assets of the enterprise (and relevant information of its business partners) from threats, risk, and exposures that could occur.

D2-Q78: Risk-Aware Business Decisions

Question

Which MOST enables risk-aware business decisions?

- A Robust information security policies
- B Exchange of accurate and timely information
- C Skilled risk management personnel
- D Skilled risk management personnel

D2-Q78: Answer

Correct Answer: B

Robust exchange of information enables management to optimize risk-related decisions. Accuracy and timeliness of information are critical success factors; the flow should be bidirectional.

D2-Q79: Initial Stages of Risk Program

Question

Which requirement MUST be met during the initial stages of developing a risk management program?

A. Management establishes ownership of identified risk
B. Information security policies and standards are established
C. A management committee exists to provide program oversight
D. The context and purpose of the program are defined

D2-Q79: Answer

Correct Answer: D

Initial requirements to determine the enterprise's purpose for creating an information security risk management program include determining the desired outcomes and defining objectives. Ownership, policies, and oversight come later.

D2-Q80: Effective BYOD Policy

Question

An enterprise implemented a corporate BYOD policy to reduce the risk of data leakage. Which approach MOST enables the policy to be effective?

A. Obtaining signed acceptance from users
B. Educating users on acceptable and unacceptable practices
C. Requiring users to read the policy and future updates
D. Clearly stating disciplinary action for noncompliance

D2-Q80: Answer

Correct Answer: B

A BYOD policy that is approved and communicated will not be effective without proper training of all users. Signed acceptance does not imply understanding; reading and disciplinary statements are secondary.

D2-Q81: New Regulation First Action

Question

A new regulation for safeguarding information processed by a specific transaction type comes to an IT manager's attention. The manager should FIRST:

A. Meet with stakeholders to decide how to comply
B. Analyze the key risk in the compliance process
C. Update the existing security/privacy policy
D. Assess whether existing controls meet the regulation

D2-Q81: Answer

Correct Answer: D

The first step is to understand the impact and requirements of the new regulation, which includes assessing how the enterprise will comply and to what extent existing controls support compliance. The risk practitioner should then assess any existing gaps.

D2-Q82: Document Identifying Compliance Risk

Question

Which document BEST identifies an enterprise's compliance risk and corrective actions in progress to meet regulatory requirements?

- A. An internal audit report
- B. A risk register
- C. An external audit report
- D. A risk assessment report

D2-Q82: Answer

Correct Answer: B — Risk register

A risk register provides a report of all current identified risk within an enterprise (including compliance risk) and tracks the status of corrective actions or exceptions.

D2-Q83: Impact on Security Governance Models

Question

Which will have the MOST significant impact on standard information security governance models?

A. Number of employees and consulting staff
B. Cultural differences between physical locations
C. Complexity of the organizational structure
D. Uncertainty in legislative requirements

D2-Q83: Answer

Correct Answer: C

Information security governance models are highly dependent on the complexity of the organizational structure. Elements include multiple business units, dispersion of functions, multiple leadership hierarchies, and multiple lines of communication.

D2-Q84: Highest Tolerance for Public Cloud

Question

Senior management will MOST likely have the highest tolerance for moving which to a public cloud?

A. Credit-card processing
B. Research and development
C. The legacy financial system
D. The corporate email system

D2-Q84: Answer

Correct Answer: D

Of the options, the corporate email system has the least competitive distinction, complexity, and sensitive/highly classified information. Moving processes to the cloud should consider criticality, complexity, and classification of the data.

D2-Q85: Risk Profile Consideration

Question

Which item is MOST important to consider in relation to a risk profile?

- A. A summary of regional loss events
- B. Aggregated risk to the enterprise
- C. A description of critical risk
- D. An analysis of historical loss events

D2-Q85: Answer

Correct Answer: B

The risk profile is based on the aggregated risk to the enterprise, including historical risk, critical risk, and emerging risk. Regional loss events, critical risk alone, and historical loss analysis are subsets.

D2-Q86: Collaborative Research Cloud

Question

Which cloud deployment model is MOST appropriate for a collaborative research program between universities?

A. Private cloud
B. Community cloud
C. Public cloud
D. Hybrid cloud

D2-Q86: Answer

Correct Answer: B — Community cloud

A community cloud is shared between several enterprises and supports a specific community with a common mission or interest. Private is for a single enterprise; public is for the general public; hybrid combines models.

D2-Q87: Control Environment Review Line

Question

Which line of defense is MOST likely involved when conducting a review of the adequacy of the control environment?

A. The first line of defense
B. The second line of defense
C. The third line of defense
D. Third-party line of defense

D2-Q87: Answer

Correct Answer: A — First line

A control environment review is a first line of defense activity, where control owners are responsible for adequacy of the control environment. The second line provides risk-based consultation and monitoring; the third provides independent assurance.

D2-Q88: Board Concern on Risk Capability

Question

Which issue would be of MOST concern to the board when assessing risk management capability?

A. The third line acts independently of the other lines
B. The second line is checking and challenging the first line
C. Internal audit is preparing the risk management strategy
D. Each line of defense is conducting its own planning independently

D2-Q88: Answer

Correct Answer: D

Joint planning across the three lines of defense is key to achieving an effective risk management capability. If each line is planning independently, the lines of defense are not working as expected.

D2-Q89: Supporting Code of Ethics

Question

Which MOST effectively supports adherence to an enterprise's code of ethics?

- A Ensuring periodic training, evaluation, and attestation of employees
- B Performing background checks at hire
- C Providing clear enterprise policies and standards
- D Providing continuous awareness of ethical requirements

D2-Q89: Answer

Correct Answer: A

Attestation to comply with the code of conduct during ethics training ensures employees have a clear idea of what is expected. Training also provides evaluation to measure understanding. Background checks and policies alone are less effective.

D2-Q90: Explaining Zero-Day Exploit

Question

Who is responsible for explaining the ramifications of a new zero-day exploit to senior management?

- A Chief operating officer
- B Chief risk officer
- C Chief information security officer
- D Chief information officer

D2-Q90: Answer

Correct Answer: B — Chief risk officer

The chief risk officer is the most senior official accountable for all aspects of risk management across the enterprise, including explaining risk to senior management. The CISO leads the security program but is not responsible for enterprise risk acceptance.

D2-Q91: Information Classification Responsibility

Question

The application of information classification is the responsibility of the:

A. Information security officer
B. Information owner
C. Information systems auditor
D. Information custodian

D2-Q91: Answer

Correct Answer: B — Information owner

The information owner determines classification based on the criticality and sensitivity of information. The security officer, auditor, and custodian have different responsibilities.

D2-Q92: Three Lines of Defense Benefit

Question

The MOST significant benefit of using the three lines of defense model in a risk management framework is that it:

A. Ensures ongoing success of the risk management initiative
B. Enhances communication between various stakeholders
C. Clarifies essential roles of the key stakeholders
D. Helps risk owners in selecting appropriate control owners

D2-Q92: Answer

Correct Answer: C

The three lines of defense model is designed to assign roles related to risk, controls, and security while better defining and understanding the relationships between them.

D2-Q93: First Line of Defense Role

Question

Which risk management role is part of the first line of defense?

A. Chief risk officer
B. Risk steering committee
C. Risk owner
D. Board of directors

D2-Q93: Answer

Correct Answer: C — Risk owner

The first line of defense is operational management, and risk owners are part of operational management. The CRO and risk steering committee are second line; the board provides direction and oversight.

D2-Q94: Ultimate Objective of Risk Governance

Question

What is the ULTIMATE objective of risk governance?

A. Benefits realization
B. Risk optimization
C. Resource optimization
D. Value creation

D2-Q94: Answer

Correct Answer: D — Value creation

Value creation is the main objective of risk governance and is achieved when the three underlying objectives (benefits realization, risk optimization, and resource optimization) are balanced.

D2-Q95: Second Line of Defense Activity

Question

Which activity would be a direct responsibility of the second line of defense?

- A Establish a risk management framework
- B Identify, assess, and respond to risk
- C Implement information security controls
- D Test and report control effectiveness

D2-Q95: Answer

Correct Answer: A

Establishing a risk management framework, providing awareness training, and supervising overall risk management are responsibilities of the second line of defense. Identifying/assessing/responding is first line; testing controls is third line.

D2-Q96: Ethical Behavior Contribution

Question

Developing and practicing ethical behavior within an enterprise contributes the most to:

A. Determining the risk appetite
B. Building the risk culture
C. Enhancing risk management
D. Increasing risk tolerance

D2-Q96: Answer

Correct Answer: B — Building the risk culture

Practicing professional ethics within an enterprise helps stakeholders review risk associated with unethical behavior before making decisions. This establishes the risk culture of the enterprise.

D2-Q97: Benefits of Professional Ethics

Question

Which is the MOST important benefit when stakeholders promote and follow professional ethics?

A. It increases reliability in risk management processes
B. It increases risk management effectiveness within an enterprise
C. It improves compliance with regulatory requirements
D. It improves the enterprise's reputation and business growth

D2-Q97: Answer

Correct Answer: B

When stakeholders follow ethical practices, actions and decisions are based on reviewing the results and impact of those actions. This promotes a risk-based approach to decision-making and enhances overall risk management.

D2-Q98: Best Proactive Ethics Approach

Question

Which is the BEST proactive approach for practicing professional ethics within an enterprise?

A. Develop an ethics policy
B. Implement processes to report unethical behavior
C. Define procedures for disciplinary action
D. Provide ethics awareness training

D2-Q98: Answer

Correct Answer: D

Awareness training is the most proactive approach to improve professional ethics within an enterprise. Training informs employees on the code of ethics and enables them to make decisions and take appropriate action. Reporting and discipline are reactive.

D2-Q99: Ensuring 3LoD Effectiveness

Question

Which is the MOST critical to ensure the three lines of defense work together effectively?

A. A documented disaster recovery plan
B. Automated operational processes
C. Independent external audits
D. Clear, detailed roles and responsibilities

D2-Q99: Answer

Correct Answer: D

Without clear, detailed job descriptions for employees working in each line of defense, there can be confusion on what is expected at each level, which may hinder effectiveness.

D2-Q100: What Should Drive IT Plan

Question

Which should drive the IT plan?

A. Strategic planning and business requirements
B. Technology and operational procedures
C. Compliance with laws and regulations
D. Project plans and stakeholder requirements

D2-Q100: Answer

Correct Answer: A

IT exists to support business objectives. Management of enterprise IT should align the IT plan closely with the business. Compliance and project plans are evaluated in the context of business risk.

D3-Q101: Outsourced Noncore Process Concern

Question

Which outcome of outsourcing noncore processes is of GREATEST concern to management?

A. Total cost of ownership exceeds projections
B. Internal information systems experience is lost
C. Employees of the vendor are disloyal to the client
D. Processing of sensitive data is subcontracted by the vendor

D3-Q101: Answer

Correct Answer: D

The greatest risk in third-party relationships is ceding direct control of IS processes. Subcontracting increases this risk; the subcontracting process must be reviewed because sensitive data are involved.

D3-Q102: Proposing Risk Treatment

Question

When proposing the implementation of a specific risk treatment, a risk practitioner PRIMARILY uses a:

A. Technical evaluation report
B. Business case
C. Vulnerability assessment report
D. Budgetary requirements

D3-Q102: Answer

Correct Answer: B — Business case

A manager should base any proposed risk response on a risk assessment in the context of business objectives. The manager must document costs of controls and compare them against benefits of the risk response.

D3-Q103: Most Important for Effective Risk Management

Question

Which is MOST important for effective risk management?

- A Assignment of risk owners to identified risk
- B Ensuring compliance with regulatory requirements
- C Integration of risk management into operational processes
- D Implementation of a risk avoidance strategy

D3-Q103: Answer

Correct Answer: A

It is of utmost importance to assign risk to individual owners and therein maximize accountability. Regulatory compliance is a relatively small part of risk management; risk avoidance is not always feasible.

D3-Q104: Most Important Outsourcing Question

Question

An enterprise outsourced several business functions including IT development, data hosting, and support. What is the MOST important question regarding the outsourcing arrangements?

A. Are policies and procedures in place to handle security exceptions?
B. Is the supplier meeting the terms of the SLAs?
C. Is the provider's security program based on an international standard?
D. Are specific security controls mandated in the outsourcing contract?

D3-Q104: Answer

Correct Answer: D

Without enumerating security requirements directly in the outsourcing contract, the outsourcing company has no assurance that the provider will comply with specific security requirements.

D3-Q105: Basis for Establishing Risk Ownership

Question

Which activity provides the BEST basis for establishing risk ownership?

A. Documenting interdependencies between departments
B. Mapping identified risk to a specific business process
C. Referring to available RACI charts for business processes
D. Distributing risk among identified business process owners

D3-Q105: Answer

Correct Answer: B

Mapping identified risk to a specific business process helps identify the process owner. Aggregation of related business processes results in identification of the prospective risk owner. Ownership cannot be shared.

D3-Q106: Risk Response Report Recommendations

Question

A risk response report includes recommendations for:

A. Acceptance
B. Assessment
C. Evaluation
D. Quantification

D3-Q106: Answer

Correct Answer: A — Acceptance

Acceptance of a risk is an alternative to be considered in the risk response process. Assessment, evaluation, and quantification occur earlier in the risk process.

D3-Q107: Reduced to Achieve Acceptable Risk

Question

Which is MOST likely to be reduced to achieve acceptable risk?

A. Risk appetite
B. Control risk
C. Residual risk
D. Inherent risk

D3-Q107: Answer

Correct Answer: C — Residual risk

Residual risk is the remaining risk after management has implemented a risk response. Acceptable risk is achieved when residual risk is reduced to levels within the enterprise's risk appetite.

D3-Q108: Denial-of-Service Vulnerability Decision

Question

A global financial institution decided not to take further action on a denial-of-service vulnerability. The MOST likely reason is:

A. The needed countermeasure is too complicated to deploy

B. There are sufficient safeguards to prevent this risk

C. The likelihood of the risk occurring is unknown

D. The cost of countermeasure outweighs the value of the asset and potential loss

D3-Q108: Answer

Correct Answer: D

An enterprise may decide to accept a specific risk because the protection would cost more than the potential loss.

D3-Q109: Two-Factor Authentication Cost-Benefit

Question

Which is MOST relevant to include in a cost-benefit analysis of a two-factor authentication system?

A. The approved budget of the project
B. The frequency of incidents
C. The annual loss expectancy of security incidents
D. The total cost of ownership

D3-Q109: Answer

Correct Answer: D

Total cost of ownership is the most relevant piece of information because it establishes a cost baseline that must be considered for the full life cycle of the control. Frequency and ALE have indirect relationships.

D3-Q110: Most Important Outsourcing Contract Part

Question

Which is the MOST important part of any outsourcing contract?

A. The right to audit the outsourcing provider
B. Provisions to assess the compliance of the provider
C. Procedures for dealing with incident notification
D. Requirements to encrypt hosted data

D3-Q110: Answer

Correct Answer: B

If a contract contains no provision to monitor and hold a supplier accountable for security, then the outsourcing enterprise cannot ensure compliance or proper handling of its data.

D3-Q111: Greatest Risk with Cloud Provider

Question

Which poses the GREATEST risk to an enterprise that recently engaged a cloud provider?

A. The cloud provider's primary facility is in the same vicinity
B. The service level agreement is ambiguous
C. References from other customers were not obtained
D. Auditing the vendor requires dependence on a third-party audit firm

D3-Q111: Answer

Correct Answer: B

If the service level agreement is ambiguous, it will be difficult to determine whether the provider complies. References cannot provide reasonable assurance; third-party audits are permitted under SSAE 18.

D3-Q112: Insuring Against Unmitigable Risk

Question

When a risk cannot be sufficiently mitigated through manual or automatic controls, which option will BEST protect the enterprise from the potential financial impact?

- A Insuring against the risk
- B Updating the IT risk registry
- C Improving staff training in the risk area
- D Outsourcing the related process to a third party

D3-Q112: Answer

Correct Answer: A

An insurance policy can compensate the enterprise monetarily for the impact of the risk by transferring the risk to the insurance company. Updating the register changes perception only; outsourcing does not remove the risk.

D3-Q113: Cost of Mitigation Exceeds Benefit

Question

After a risk assessment, it is determined that the cost to mitigate the risk is much greater than the benefit to be derived. The BEST risk response is that the risk be:

A. Treated
B. Terminated
C. Accepted
D. Transferred

D3-Q113: Answer

Correct Answer: C — Accepted

When the cost of control is more than the cost of the potential impact, the risk should be accepted.

D3-Q114: Improving Continuity of Operations

Question

A data center provider's clients complain of frequent service disruptions. Management sets up a project team to improve continuity. Which risk management activity will MOST benefit this initiative?

- A Develop key risk indicators
- B Determine risk and control ownership
- C Update the risk register
- D Develop IT risk scenarios

D3-Q114: Answer

Correct Answer: D

The relationship between IT risk scenarios and business impact must be established to understand the effects of possible adverse events on enterprise objectives. A risk scenario directly identifies circumstances that can adversely affect business or assets.

D3-Q115: Reciprocal Agreement for Equipment

Question

Critical IT equipment will be delivered late due to flooding, but a reciprocal agreement exists with another company for a replacement until it arrives. This is an example of risk:

- A Transfer
- B Avoidance
- C Acceptance
- D Mitigation

D3-Q115: Answer

Correct Answer: D — Mitigation

Risk mitigation attempts to reduce the impact when a risk event occurs. Making plans such as a reciprocal arrangement reduces the consequence of the risk event.

D3-Q116: Selecting an Appropriate Risk Response

Question

Which would BEST help an enterprise select an appropriate risk response?

- A. An analysis of change in the risk environment
- B. An analysis of risk that can be transferred
- C. An analysis of likelihood and impact of risk scenarios
- D. An analysis of control costs and benefits

D3-Q116: Answer

Correct Answer: D

An analysis of costs and benefits for controls helps an enterprise understand if it can mitigate the risk to an acceptable level. Likelihood and impact establish the risk level but are inadequate for selecting the response.

D3-Q117: Optimal Return on Security Investment

Question

Which leads to the BEST optimal return on security investment?

- (A) Deploying maximum protection across all information assets
- (B) Focusing on the most important information assets and then determining their protection
- (C) Deploying minimum protection across all information assets
- (D) Investing only after a major security incident is reported

D3-Q117: Answer

Correct Answer: B

To optimize return on security investment, focus on identifying important information assets and protect them appropriately. Maximum protection overprotects less critical assets; minimum protection compromises critical assets; reactive investing may be too late.

D3-Q118: Compromised Administrator Account Impact

Question

Which control can reduce the potential impact of a malicious hacker who gains access to an administrator account?

A. Multifactor authentication
B. Audit logging
C. Least privilege
D. Password policy

D3-Q118: Answer

Correct Answer: C — Least privilege

Least privilege can reduce the impact of a compromised account within the scope of its intended use and limit impact to the enterprise as a whole. MFA is already bypassed; audit logging is a lagging indicator; password policy does not limit scope.

D3-Q119: Critical Element of Effective Risk Program

Question

Which is critical to the risk practitioner for an effective risk management program?

A. Risk response strategy
B. Risk register content
C. Risk profile content
D. Risk owners and accountability

D3-Q119: Answer

Correct Answer: D

The identification of risk owners is critical because risk owners must make informed and cost-effective decisions regarding appropriate controls to mitigate their owned risk. Strategy, register, and profile are tools that require proactive users with accountability.

D3-Q120: Anti-Malware Cost Exceeds Loss

Question

Where the cost of anti-malware exceeds the loss expectancy of malware threats, what is the MOST viable risk response?

A. Risk elimination
B. Risk acceptance
C. Risk transfer
D. Risk mitigation

D3-Q120: Answer

Correct Answer: B — Risk acceptance

When the cost of a risk response exceeds the loss expectancy, the most viable risk response is risk acceptance. Transfer and mitigation must also be based on cost-benefit analysis.

D3-Q121: Best Example of Risk Avoidance

Question

Which is the BEST example of risk avoidance behavior?

- A Taking no action against the risk
- B Outsourcing the related process
- C Insuring against a specific event
- D Exiting the process that gives rise to risk

D3-Q121: Answer

Correct Answer: D

Avoidance means exiting the activities or conditions that give rise to risk. Examples include relocating a data center away from a hazard-prone region or declining to engage in a very large project with a notable risk of failure.

D3-Q122: Addressing Critical Dependencies

Question

Which would ensure that critical dependencies are addressed in the risk treatment plan?

A. Implement the risk treatment strategy for all possible risk
B. Verify the accomplishment of business objectives through a top-down process review
C. Treat each risk independently
D. Verify the accomplishment of business objectives through a bottom-up process review

D3-Q122: Answer

Correct Answer: B

Development of an overall risk treatment strategy should be a top-down process, driven jointly by the need to achieve business objectives and to apply economically feasible constraints while controlling uncertainty within the enterprise risk appetite.

D3-Q123: CISO Recommending Controls

Question

A CISO recommends several controls, such as anti-malware, to protect the enterprise's information systems. Which approach to handling risk is being recommended?

- A Risk transference
- B Risk mitigation
- C Risk acceptance
- D Risk avoidance

D3-Q123: Answer

Correct Answer: B — Risk mitigation

By implementing controls, the company is trying to reduce the risk to an acceptable level, thereby mitigating risk.

D3-Q124: Best Practice for Outsourcing Risk

Question

Which practice BEST mitigates the risk associated with outsourcing a business function?

A. Performing audits to verify compliance with contract requirements
B. Requiring all vendor staff to complete annual awareness training
C. Retaining copies of all sensitive data on internal systems
D. Reviewing the financial records of the vendor

D3-Q124: Answer

Correct Answer: A

When an outsourcing relationship is established, the risk of noncompliance with the agreement must be met through review, monitoring, and enforcement of contract terms. Regular audits verify vendor compliance.

D3-Q125: Best Addressed by Transferring Risk

Question

Which is BEST addressed by transferring risk?

A. An antiquated fire suppression system in the computer room
B. The threat of disgruntled employee sabotage
C. The threat of disgruntled employee theft
D. A building located in a 100-year flood plain

D3-Q125: Answer

Correct Answer: D

Purchasing an insurance policy transfers the risk of a flood. Risk transfer is the process of assigning risk to another entity, usually through the purchase of an insurance policy or through outsourcing the service.

D3-Q126: Finalizing Risk Treatment Plan

Question

Which would BEST help finalize the risk treatment plan?

A. Vulnerability analysis
B. Impact analysis
C. Cost-benefit analysis
D. SWOT analysis

D3-Q126: Answer

Correct Answer: C

A cost-benefit analysis helps determine if the benefit of a control outweighs the cost of implementing the control.

D3-Q127: Greatest Benefit of Risk Treatment Plan

Question

The GREATEST benefit of implementing a risk treatment plan is:

A. To reduce the impact and likelihood of risk occurrence
B. To identify unmitigated risk that can be transferred
C. To exploit the risk to test organizational preparedness
D. To enhance the overall risk appetite of the enterprise

D3-Q127: Answer

Correct Answer: A

Implementing the risk treatment plan reduces the negative impact and likelihood of a risk occurrence.

D3-Q128: Validating Patching Program

Question

What is the BEST method to validate the effectiveness of an enterprise's patching program?

A. Conduct penetration testing

B. Conduct a risk identification initiative

C. Carry out vulnerability scans

D. Review the requests for change

D3-Q128: Answer

Correct Answer: C

Performing vulnerability scans enables the IT risk practitioner to determine if patches are being installed on a timely basis. Penetration testing can elevate risk on production systems; RFCs do not prove patches are applied.

D3-Q129: Designing IS Controls in Complex Environment

Question

Which is the MOST important factor when designing information systems controls in a complex environment?

A. Development methodologies
B. Scalability of the solution
C. Technical platform interfaces
D. Stakeholder requirements

D3-Q129: Answer

Correct Answer: D

The most important factor when designing IS controls is their ability to advance the interests of the business by addressing stakeholder requirements.

D3-Q130: EFT Testing Focus

Question

A financial institution is testing its EFT system after major enhancements. The risk practitioner would MOST benefit from a test that:

A. Identifies the introduction of potential new gaps in security
B. Verifies adequate system recovery in case of failure
C. Ensures the system performs to expectation
D. Ensures the system can support transaction volume

D3-Q130: Answer

Correct Answer: A

The security of an EFT system is of the most interest to a risk practitioner. Testing should identify the introduction of potential new gaps in information security.

D3-Q131: Creating KRIs for Quarterly Reporting

Question

What is the BEST approach for creating KRIs for quarterly reporting to senior leadership?

A. Survey senior leaders about primary risk concerns
B. Identify the most common network vulnerabilities
C. Determine KRIs used in similar industry verticals
D. Identify the enterprise risk appetite and metrics of current risk

D3-Q131: Answer

Correct Answer: D

KRIs are measurable and quantifiable indicators of risk. Creation of KRIs should be based on the enterprise's risk appetite and the measures available. Survey feedback is subjective; vulnerabilities lack likelihood/impact; other industries differ.

D3-Q132: Gauging Stakeholder Concern

Question

An enterprise contracted an external supplier for critical components. Risk tolerance levels for the outsourced component are documented and approved. Which can serve to gauge risk that may trigger stakeholder concern?

- A Indicators with approved thresholds
- B Approved status report of completed milestones
- C List of controls to be implemented by the supplier
- D Number of findings in external audit reports

D3-Q132: Answer

Correct Answer: A

Indicators with approved thresholds demonstrate the acceptable risk levels stakeholders are willing to tolerate, and any risk above those approved levels will likely trigger stakeholder concern.

D3-Q133: Revoking Temporary User Access

Question

Which control within the user provision process BEST ensures revocation of system access for contractors and temporary users when no longer required?

A. Log account usage and send it to managers

B. Establish predetermined, automatic expiration dates

C. Ensure each user signs a security acknowledgment

D. Require managers to email security when the user leaves

D3-Q133: Answer

Correct Answer: B

Predetermined expiration dates are the most effective means of removing systems access for temporary users. Logging is detective; acknowledgment has little effect; managers often delay termination notices.

D3-Q134: Presenting Risk Profile to Board

Question

Which BEST helps while presenting the current risk profile to executive management and the board?

A. Risk response dashboard
B. Emerging risk report
C. Risk register dashboard
D. Key risk indicators report

D3-Q134: Answer

Correct Answer: C

A risk register dashboard provides a comprehensive overview of the risk profile of the enterprise. Risk response is a component; KRI report is only one component; emerging risk is not the full profile.

D3-Q135: Senior Management Monitoring KCIs

Question

What is the MAIN reason senior management monitors and analyzes trends in key control indicators?

A. It provides feedback on the overall control environment
B. It helps in identifying redundant controls
C. It proactively identifies impacts to the risk profile
D. It helps determine if additional controls are required

D3-Q135: Answer

Correct Answer: C

The primary objective of KCIs is to ensure that controls actually mitigate risk at an effective level. Analysis of KCI trends provides information on the overall effectiveness of controls and the status of risk management.

D3-Q136: Risk Treatment Plans Purpose

Question

Risk treatment plans are necessary to describe how the:

A. Identified risk is further analyzed
B. Chosen treatment options will be implemented
C. Accepted risk is treated
D. Risk indicators will monitor the risk

D3-Q136: Answer

Correct Answer: B

A risk treatment plan includes the plan of action for the chosen treatment, how it will be implemented, who will implement it, key dates, and resource requirements. Once risk is accepted, a treatment plan is not needed.

D3-Q137: Cost-Benefit Analysis Stage

Question

In the risk management process, a cost-benefit analysis is MAINLY performed:

A. As part of an initial risk assessment
B. As part of risk-response planning
C. During an information asset valuation
D. When insurance is calculated for risk transfer

D3-Q137: Answer

Correct Answer: B

In risk response, a range of controls that can mitigate risk will be identified; a cost-benefit analysis helps identify the right controls to address the risk at acceptable levels within the budget.

D3-Q138: Insufficient Resources for Treatment

Question

In the event that available resources for risk treatment are not sufficient, the risk treatment plan should:

A. Define the priorities across all treatments to assist in resource allocation

B. Recommend postponing treatment until resources are available

C. Recommend reassessing the risk treatment options

D. Suggest increasing the priority of the treatment

D3-Q138: Answer

Correct Answer: A

When available resources for treating the risk are not sufficient, the risk treatment plan should include prioritization of the risk so resources can be properly allocated.

D3-Q139: System Backup and Restore Classification

Question

System backup and restore procedures can BEST be classified as:

A. Technical controls
B. Detective controls
C. Corrective controls
D. Deterrent controls

D3-Q139: Answer

Correct Answer: C — Corrective controls

Corrective controls remediate the impact from negative events. If a system suffers harm so extensive that processing cannot continue, backup restore procedures enable that system to be recovered.

D3-Q140: Primary Reason for Policy Exception

Question

A PRIMARY reason for initiating a policy-exception process is:

A. The risk is justified by the benefit
B. Policy compliance is difficult to enforce
C. Operations are too busy to comply
D. Users may initially be inconvenienced

D3-Q140: Answer

Correct Answer: A

Exceptions to policies are warranted if the benefits outweigh the costs of policy compliance; however, the enterprise needs to assess both the tangible and intangible risk and evaluate both in the context of existing risk.

D3-Q141: Measuring Operational Controls

Question

Which would BEST measure the effectiveness of operational controls?

A. Control matrix
B. Key performance indicator
C. Statement of applicability
D. Key control indicator

D3-Q141: Answer

Correct Answer: D — KCI

Key control indicators, also referred to as control effectiveness indicators, are metrics that provide information on the degree to which a control is working.

D3-Q142: Selecting Security Technologies

Question

Security technologies should be selected PRIMARILY on the basis of their:

A. Evaluation in security publications
B. Compliance with industry standards
C. Ability to mitigate risk to organizational objectives
D. Cost compared to the enterprise's IT budget

D3-Q142: Answer

Correct Answer: C

The most fundamental criterion for selecting security technology is the capacity to reduce risk to organizational objectives.

D3-Q143: Before Black Box Penetration Test

Question

Which should be in place before a black box penetration test begins?

- (A) A clearly stated definition of scope
- (B) Previous test results
- (C) Proper communication and awareness training
- (D) An incident response plan

D3-Q143: Answer

Correct Answer: A

A clearly stated definition of scope ensures a proper understanding of risk and success criteria. Previous results may inform scope; training and IR plan are not prerequisites.

D3-Q144: Securing Corporate Network Against External Attack

Question

What is the BEST way to ensure that a corporate network is adequately secured against external attack?

A. Use an intrusion detection system

B. Establish minimum security baselines

C. Implement vendor recommended settings

D. Perform periodic penetration testing

D3-Q144: Answer

Correct Answer: D

Penetration testing is the best way to ensure that perimeter security is adequate. IDS is detective; baselines and vendor settings provide good practice but not assurance.

D3-Q145: Before Establishing KCIs

Question

Which is PRIMARILY defined before establishing key control indicators?

- A Desired capacity
- B Desired risk threshold
- C Desired tolerances
- D Desired risk appetite

D3-Q145: Answer

Correct Answer: C — Desired tolerances

The goal of KCIs is to track performance of control actions relative to tolerances, providing insight into the ongoing adequacy of a control in keeping risk within acceptable levels. Tolerances must be defined first.

D3-Q146: Substantive Test of Tape Inventory

Question

A substantive test to verify that tape library inventory records are accurate involves:

A. Determining whether bar code readers are installed
B. Conducting a physical count of the tape inventory
C. Checking whether receipts and issues of tapes are accurately recorded
D. Determining whether movement of tapes is authorized

D3-Q146: Answer

Correct Answer: B

A substantive test involves gathering evidence to evaluate the integrity of individual transactions, data, or other information. A physical count of the tape inventory is a substantive test; the others are compliance tests.

D3-Q147: Ensuring Mitigation of Vulnerabilities

Question

Which BEST ensures that appropriate mitigation occurs on identified information systems vulnerabilities?

- A Presenting root cause analysis to management
- B Implementing software to input action points
- C Incorporating findings into the annual report
- D Assigning action plans with deadlines to responsible personnel

D3-Q147: Answer

Correct Answer: D

Assigning mitigation to personnel establishes responsibility for its completion within the deadline. Presenting findings raises awareness but does not ensure action; software and reporting do not guarantee completion.

D3-Q148: Audit Report on Uncritical Functions

Question

What is the BEST action if an audit report recommends supplemental controls for uncritical functions?

- A Appoint a project lead to start implementation
- B Eliminate the risk by purchasing risk insurance
- C Request that IT implement all supplemental controls
- D Request a cost-benefit analysis to determine business need

D3-Q148: Answer

Correct Answer: D

A cost-benefit analysis may help determine if supplemental controls are needed, ensuring the cost of the control does not exceed the impact from the risk being realized.

D3-Q149: Peer Review of Risk Management

Question

Which BEST enables a peer review of an enterprise's risk management process?

A. A balanced scorecard
B. An industry survey
C. A capability maturity model
D. A framework

D3-Q149: Answer

Correct Answer: C

A capability maturity model describes essential elements and criteria for effective processes and outlines an evolutionary improvement path from ad hoc to disciplined, mature processes.

D3-Q150: Risk Treatment Plan With Resolution

Question

Which is the MOST important information to include in a risk treatment plan that already has an appropriate resolution and a date for completion?

A. Responsible personnel
B. Mitigating factors
C. Likelihood of occurrence
D. Cost of completion

D3-Q150: Answer

Correct Answer: A

Risk response activities must be assigned to a responsible person or group; without this assignment, it will be unclear who will implement the countermeasure.

D3-Q151: Ensuring Risk Remains Acceptable

Question

Which BEST ensures that identified risk remains at an acceptable level?

- A Reviewing controls periodically according to the risk treatment plan
- B Listing each risk as a separate entry in the risk register
- C Creating a separate risk register for every department
- D Maintaining a KRI for assets in the risk register

D3-Q151: Answer

Correct Answer: A

Controls deployed according to the risk treatment plan should provide the desired results, because the plan is based on management's acceptance of residual risk and approval of deployment steps.

D3-Q152: Risk Response Increasing Liability

Question

Which risk response option is MOST likely to increase the liability of the enterprise?

- A Risk acceptance
- B Risk reduction
- C Risk transfer
- D Risk avoidance

D3-Q152: Answer

Correct Answer: A — Risk acceptance

An enterprise may choose to accept risk without knowing the correct level of risk being accepted; this may result in accusations of negligence.

D3-Q153: Best Reason Not to Reduce Risk

Question

Which is the BEST reason for an enterprise to decide not to reduce an identified risk?

A. There is no regulatory requirement to reduce the risk
B. There are mitigating controls in place
C. The cost of mitigation exceeds the risk
D. The budget for risk mitigation is limited

D3-Q153: Answer

Correct Answer: C

Enterprises will accept the risk when the cost of mitigation exceeds the risk. Regulatory requirement, existing controls (residual may still exceed tolerance), and budget alone are insufficient reasons.

D3-Q154: Outsourcing Part of IT Activities

Question

An enterprise decides to address risk associated with an IT project by outsourcing part of the IT activities to a third party with a specialized skill set. In relation to the project, this is an example of:

- A Risk transfer
- B Risk avoidance
- C Risk acceptance
- D Risk mitigation

D3-Q154: Answer

Correct Answer: D — Risk mitigation

When specific activities are outsourced to an entity with a specialized skill set, the inherent risk of the activity is reduced. The outsourcing process works as a control in this case.

D3-Q155: Facilitating Cost-Effective Risk Response

Question

Which BEST facilitates cost-effective risk response?

- (A) Prioritizing and addressing risk according to the risk management strategy
- (B) Mitigating risk on the basis of likelihood and magnitude of impact
- (C) Performing countermeasure analysis for each control deployed
- (D) Selecting controls that are at zero or near-zero costs

D3-Q155: Answer

Correct Answer: A

Prioritizing and addressing risk in line with the risk treatment strategy balances the costs and benefits of managing the IT risk. Likelihood/impact alone do not optimize treatment; zero-cost controls may be ineffective.

D3-Q156: Recommending DLP Device

Question

Which can BEST be used as a basis for recommending a data loss prevention (DLP) device as a security control?

A. Benchmarking with peers on DLP deployment
B. A business case for DLP to protect data
C. Evaluation report of popular DLP solutions
D. Data leakage scenario in risk register

D3-Q156: Answer

Correct Answer: B

A business case with costs versus benefits provides the business reasoning for why the DLP solution addresses the risk and explains how risk losses could be reduced.

D3-Q157: Cost Greater Than Opportunity

Question

When the cost of risk related to a specific business process is greater than the potential opportunity, the BEST risk response is:

A. Transfer
B. Acceptance
C. Mitigation
D. Avoidance

D3-Q157: Answer

Correct Answer: D — Avoidance

Risk avoidance is the process for systematically avoiding risk, constituting one approach to managing risk. When risk cost exceeds the potential opportunity, avoiding the activity is best.

D3-Q158: First Step When Outsourcing All IT

Question

What is the FIRST step for a risk practitioner when an enterprise decides to outsource all IT services and support to a third party?

A. Validate that the internal systems of the provider are secure

B. Enforce transborder data flow regulations

C. Ensure security requirements are addressed in all contracts and agreements

D. Build a business case to perform an on-site audit of the vendor

D3-Q158: Answer

Correct Answer: C

A contract only covers topics listed in the contract. If security is not explicitly included in the contract terms, the enterprise may not be properly protected.

D3-Q159: Justifying IT Control Cost

Question

Which BEST helps ensure that the cost is justifiable when selecting an IT control?

- A. The investment cost is within budget
- B. The risk likelihood and impact are reflected
- C. The net present value of the IT control cost is high
- D. Low-cost open source technology is used

D3-Q159: Answer

Correct Answer: B

While other factors may be relevant, the total cost of ownership of a control should not exceed the projected likelihood times the impact of the risk it is intended to mitigate.

D3-Q160: Testing Compliance of Response Plan

Question

Testing compliance of a response and recovery plan should begin by conducting a:

A. Tabletop exercise
B. Review of archived logs
C. Penetration test
D. Business impact analysis

D3-Q160: Answer

Correct Answer: A

Tabletop exercises simulate incidents to test the response capability of an enterprise. Participants gather to formulate responses to each development in realistic scenarios.

D3-Q161: Capability Maturity Model Basis

Question

The use of a capability maturity model is based on:

A. The training of staff
B. The development of new controls
C. The application of standard, repeatable processes that can be measured
D. Users developing new innovative solutions

D3-Q161: Answer

Correct Answer: C

The use of maturity models requires development, implementation, and measuring of consistent procedures and activities. Maturity models describe an evolutionary path from ad hoc to mature, measured processes.

D3-Q162: Internal Control Requirements Source

Question

An enterprise is implementing controls to protect employee details from unauthorized exposure. The internal control requirements will come from:

A. The risk management team
B. Internal audit
C. IT management
D. Process owners

D3-Q162: Answer

Correct Answer: D — Process owners

Process owners provide the internal control requirements based on the business needs and objectives. Risk management reviews control risk; audit measures effectiveness; IT handles IT governance.

D3-Q163: Costs Balanced with Potential Loss

Question

Which costs MUST be balanced with the potential for loss to ensure effective risk management?

A. Regulatory fines and penalties
B. Total cost of ownership
C. Breach management cost
D. Business operation cost

D3-Q163: Answer

Correct Answer: B

Total cost of ownership considers implementation and operating costs for a control, which must be balanced with the potential for loss to ensure effective risk management.

D3-Q164: Controls Design Reduction

Question

Controls are most effective when they are designed to reduce:

A. Threats
B. Likelihood
C. Uncertainty
D. Vulnerabilities

D3-Q164: Answer

Correct Answer: D — Vulnerabilities

Controls are most effective when designed to reduce vulnerabilities affecting the enterprise. Threats cannot always be reduced; likelihood alone is one aspect; controls generally do not reduce uncertainty.

D3-Q165: Mitigating Patch Interoperability Risk

Question

System administrators may release critical patches into production without testing. Which would BEST mitigate the risk of interoperability issues?

A. Ensure a reliable system rollback plan is in place
B. Test the patch on the least critical systems first
C. Only allow updates to occur after hours
D. Ensure patches are approved by the CISO

D3-Q165: Answer

Correct Answer: A

A reliable system rollback plan allows administrators to roll back patches in case they affect the system negatively. Testing on least critical systems does not reveal impact on all applications.

D4-Q166: Information No Longer Required

Question

Information no longer required to support the main purpose of the enterprise should be managed:

A. Under the retention policy
B. Under the information classification policy
C. Under the backup policy
D. Under the business impact analysis

D4-Q166: Answer

Correct Answer: A — Retention policy

Information no longer required should be analyzed under the retention policy to determine whether the enterprise is required to maintain the data for business, legal, or regulatory reasons. Keeping data unnecessarily increases risk.

D4-Q167: Protecting Breakthrough Technology

Question

An enterprise developed a breakthrough technology providing a competitive edge. Which FIRST governs how this information is protected from within the enterprise?

- A The data classification policy
- B The acceptable use policy
- C Encryption standards
- D The access control policy

D4-Q167: Answer

Correct Answer: A

A data classification policy describes the data classification categories, the level of protection for each category, and roles and responsibilities. Encryption and access controls are driven by the classification.

D4-Q168: Most Important IS Infrastructure Requirement

Question

Which is the MOST important requirement for setting up an information security infrastructure for a new system?

- A Performing a business impact analysis
- B Considering personal devices as part of the security policy
- C Basing the information security infrastructure on a risk assessment
- D Initiating an IT security awareness campaign

D4-Q168: Answer

Correct Answer: C

The information security infrastructure should be based on a risk assessment. BIA is for continuity; personal devices may be part of policy; awareness training is supportive.

D4-Q169: Data Retention Policy Primary Concern

Question

The PRIMARY concern of a risk practitioner reviewing a formal data retention policy is:

A. Storage availability
B. Applicable organizational standards
C. Generally accepted industry good practices
D. Regulatory and business requirements

D4-Q169: Answer

Correct Answer: D

In determining the retention policy, regulatory requirements are of primary importance along with business requirements. Without them, an enterprise can keep records indefinitely at tremendous cost.

D4-Q170: Security Awareness Programs Reason

Question

Which is the MOST important reason for conducting security awareness programs throughout an enterprise?

A. Reducing the risk of social engineering attacks
B. Training personnel to respond to security incidents
C. Informing business units about the security strategy
D. Maintaining evidence of training records

D4-Q170: Answer

Correct Answer: A

Security awareness reduces the risk of successful social engineering attacks by sensitizing employees to security policies and risk. People are often the weakest link in security implementations.

D4-Q171: Incident Response Training Effective

Question

Which is the BEST indicator that incident response training is effective?

- A Decreased reporting of security incidents
- B Increased reporting of security incidents
- C Decreased number of password resets
- D Increased number of identified system vulnerabilities

D4-Q171: Answer

Correct Answer: B

Increased reporting of valid incidents is the best indicator because it shows users are aware of security rules and know how to report incidents. Decreased reporting suggests lack of awareness.

D4-Q172: Greatest Information Security Awareness

Question

Which provides the GREATEST level of information security awareness?

- A Job descriptions
- B A security manual
- C Security training
- D An organizational diagram

D4-Q172: Answer

Correct Answer: C

Security training is the best way to inform all employees about changes to the risk landscape and enhance awareness of enterprise risk management strategy.

D4-Q173: Shared Generic Account

Question

Which is the MAIN concern when two or more staff members are allowed to use the same generic account?

A. Segregation of duties
B. Inability to change the password
C. Repudiation
D. Inability to trace account activities

D4-Q173: Answer

Correct Answer: C — Repudiation

Because username and password are the same for generic accounts, repudiation becomes an issue. None of the users can be held accountable because each can deny accountability for transactions.

D4-Q174: IT Risk Awareness Campaign Approach

Question

Which is the BEST approach when conducting an IT risk awareness campaign?

A. Provide technical detail on exploits
B. Provide common messages tailored for different groups
C. Target system administrators and help desk staff
D. Target senior managers and business process owners

D4-Q174: Answer

Correct Answer: B

Groups differ in level of responsibility and expertise; tailor common messages to each group's role and understanding. Providing exploit details could enable circumvention; targeting specific groups excludes others.

D4-Q175: Social Media Outlet Greatest Concern

Question

Which principle of information security is of GREATEST concern to a social media outlet for political or news-related content?

A. Integrity
B. Confidentiality
C. Availability
D. Nonrepudiation

D4-Q175: Answer

Correct Answer: C — Availability

For a social media outlet, availability is of the greatest concern. Integrity, confidentiality, and nonrepudiation are typically the responsibility of social media users.

D4-Q176: Most Significant Threat to Project

Question

Which poses the MOST significant threat to a project?

A. A lack of feedback upon project completion
B. A lack of unit testing
C. Missed opportunities from lessons learned
D. Misunderstanding the requirements

D4-Q176: Answer

Correct Answer: D

Projects exist to deliver specific outcomes. If requirements are misunderstood, a project can succeed internally (schedule, budget) yet fail the business because it did not deliver business value.

D4-Q177: SDLC Phase for Risk Practitioner

Question

In which phase of the SDLC should a risk practitioner FIRST become involved?

A. Analysis
B. Design
C. Planning
D. Implementation

D4-Q177: Answer

Correct Answer: C — Planning

The risk practitioner should become involved as early as possible. When participating in planning, they can influence resource requests to meet risk objectives most efficiently and effectively.

D4-Q178: Project Going Over Budget

Question

Which is MOST likely to result in a project going over budget?

- A Testing
- B Scope creep
- C Loss of sponsorship
- D Quality control

D4-Q178: Answer

Correct Answer: B — Scope creep

Scope creep refers to uncontrolled changes in a project's scope. Unless scope is controlled, duration and budget cannot be held to account; the project may exceed budget to meet changing requirements.

D4-Q179: Project Risk Identification

Question

Project-related risk that can threaten the successful completion of a software development project is BEST identified by the:

A. Project manager
B. Project sponsor
C. Project steering committee
D. Quality assurance team

D4-Q179: Answer

Correct Answer: A — Project manager

The project manager is responsible for identification, analysis, and monitoring of project-related risk. Risk is reported to the project sponsor.

D4-Q180: VPN Implementation Concern

Question

Which is of MOST concern in a review of a VPN implementation?

- A Computers on the network are located at the enterprise's remote offices
- B Computers are on the enterprise's internal network
- C Computers are at the backup site
- D Computers are in employees' homes

D4-Q180: Answer

Correct Answer: D

Home computers are least often subject to the enterprise security policy and therefore are high-risk. Once a computer is compromised, any network that trusts it is at risk.

D4-Q181: BCM Meeting Stakeholder Expectations

Question

Which BEST supports business continuity management in meeting external stakeholder expectations?

A. Prioritizing applications based on business criticality
B. Ensuring backup data are available for restoration
C. Disclosing the crisis management strategy statement
D. Obtaining risk assessment by an independent party

D4-Q181: Answer

Correct Answer: A

External parties expect their information assets are secured. Prioritizing applications based on business criticality allows external expectations to be met optimally with limited resources.

D4-Q182: Cloud Computing Risk Controls

Question

Which BEST identifies controls addressing risk related to cloud computing?

A. Data encryption, tenant isolation, controlled change management
B. Data encryption, customizing the application template
C. Use of open standards technology, data encryption, tenant isolation
D. Tenant isolation, controlled change management, custom widgets

D4-Q182: Answer

Correct Answer: A

Encryption facilitates separation of data among tenants. Tenant isolation ensures that one tenant's data are sequestered from other tenants. Controlled change management ensures all changes are planned and tenant dependencies are mapped.

D4-Q183: Self-Signed Digital Certificates

Question

A financial institution conducts high-value electronic transactions using customers' self-signed digital certificates. Which is of MOST concern?

A. Self-signed certificates may not be accepted by internal browsers
B. Nonrepudiation requirements may not be enforced
C. The certificate's private key may be susceptible to attack
D. Self-signed certificates may lead to session hijacking

D4-Q183: Answer

Correct Answer: B

Nonrepudiation of transactions is critical in financial transactions. This can only be satisfied by using third party-trusted certificates signed by an accredited authority.

D4-Q184: Hardware vs Software Risk

Question

Which risk consideration is of MOST concern to the risk practitioner regarding hardware as opposed to software?

A. Misconfiguration
B. Access control
C. Skilled resources
D. Version control

D4-Q184: Answer

Correct Answer: A — Misconfiguration

Misconfiguration can lead to potential vulnerabilities, leaving the system open to external parties, and is a larger concern for hardware than software. Access control and skilled resources apply to both; version control does not apply to hardware.

D4-Q185: System Requirements Risk Phase

Question

At which phase of the SDLC should risk related to system requirements be determined?

A. Development
B. Implementation
C. Initiation
D. Maintenance

D4-Q185: Answer

Correct Answer: C — Initiation

Upon initiation of the SDLC, identified risk should inform system requirements, including security requirements and a security concept of operations.

D4-Q186: Wrong Patient File

Question

A healthcare practitioner providing care is given the file of a patient scheduled for an appointment later that day. What is the PRIMARY type of risk faced?

- A Relevance
- B Integrity
- C Security
- D Availability

D4-Q186: Answer

Correct Answer: A — Relevance risk

Relevance risk is the risk of not getting the right information to the right person at the right time for the correct action. The file provided is not relevant to that patient.

D4-Q187: Best Cloud Model for Confidential Info

Question

An enterprise accepts the risk of confidential information in the cloud. Which cloud deployment model offers the most safeguards?

A. Public cloud
B. Private cloud
C. Community cloud
D. Hybrid cloud

D4-Q187: Answer

Correct Answer: B — Private cloud

The private cloud model operates solely for the enterprise and will have controls in place needed to keep enterprise information confidential.

D4-Q188: BCP Authorship

Question

Business continuity plans should be written and maintained by:

A. The information security and IT functions
B. Representatives from all functional units
C. The risk management function
D. Executive management

D4-Q188: Answer

Correct Answer: B

Business continuity planning is an enterprise-wide activity; it is successful only if all business owners collaborate in developing, testing, and maintaining the plan. IS/IT handle DR; risk management oversees; executives ensure planning.

D4-Q189: Verifying Up-to-Date Antivirus

Question

What is the BEST way to verify that critical production servers are using up-to-date antivirus signature files?

A. Check a sample of servers
B. Verify the date signature files were last pushed out
C. Use a benign virus to test quarantine
D. Research the most recent signature file and compare to the console

D4-Q189: Answer

Correct Answer: A

The only effective way to verify currency of signature files is to look at a sample of servers. Push-out date does not guarantee loading; releasing a virus is inappropriate; console comparison does not prove loading.

D4-Q190: Security Awareness Program Effectiveness

Question

Which is MOST important for measuring the effectiveness of a security awareness program?

A. Increased interest in focus groups on security
B. A reduced number of security violation reports
C. A quantitative evaluation to ensure user comprehension
D. An increased number of security violation reports

D4-Q190: Answer

Correct Answer: D

An increase in the number of violation reports is the best indicator of a high level of security awareness. As with automated alerts, each report needs to be assessed for validity.

D4-Q191: Major Risk of Single Sign-On

Question

A MAJOR risk of single sign-on is that it:

A. Uses complex technologies for password management
B. May potentially bypass the enterprise firewall
C. Is prone to distributed denial-of-service attacks
D. May be a potential single point of compromise

D4-Q191: Answer

Correct Answer: D

Because SSO uses a single username and password for access to multiple systems, loss or disclosure of the credentials may compromise a broad range of systems.

D4-Q192: Changeover Consistency of Data

Question

Which changeover technique would have the GREATEST risk regarding consistency of data when moving users from one system to another?

A. Parallel
B. Outsourcing
C. Abrupt
D. Phased

D4-Q192: Answer

Correct Answer: C — Abrupt

Abrupt changeover occurs when users are converted immediately upon availability. It is usually least expensive but involves high risk of data loss and system failure, with no fallback to the old system.

D4-Q193: Insider Threat to Confidential Info

Question

Which is the MOST effective measure against insider threats to confidential information?

- A Audit trail monitoring
- B A privacy policy
- C Role-based access control
- D Defense in depth

D4-Q193: Answer

Correct Answer: C

Role-based access control provides access according to business need, reducing unnecessary access rights and enforcing accountability, helping guard against breaches of confidential information.

D4-Q194: Improving Awareness After Spear Phishing

Question

Despite a comprehensive awareness program, a breach occurred via spear phishing. What is the MOST effective way to improve security awareness?

A. Review and improve coverage of social engineering threats
B. Launch a disciplinary process against those who leaked information
C. Perform periodic social engineering tests and communicate summary results
D. Implement a DLP system that points users to corporate policies

D4-Q194: Answer

Correct Answer: C

Users who are aware of security threats may need a reminder that these threats are real. Periodic social engineering tests help maintain a level of alertness. Disciplinary processes are inappropriate for spear phishing.

D4-Q195: Increased Malware Attacks Recommendation

Question

IT operations indicates a heavy increase in malware attacks. Which is the MOST appropriate recommendation?

- A Contract with a new anti-malware vendor
- B Close down the Internet connection to prevent employees from visiting infected sites
- C Make the number of malware attacks part of each employee's performance metrics
- D Increase employee awareness training, including roles and responsibilities

D4-Q195: Answer

Correct Answer: D

Employee awareness training helps the enterprise avoid and more quickly detect malware attacks, particularly when staff understand typical symptoms and know the incident reporting process.

D4-Q196: When Data Warehouse Should Remain In-House

Question

Which MOST likely indicates that a customer data warehouse should remain in-house rather than outsourced offshore?

- (A) Telecommunications costs may be higher in the first year
- (B) Privacy laws may prevent a cross-border flow of information
- (C) Time zone differences may impede communications
- (D) Software development may require more detailed specifications

D4-Q196: Answer

Correct Answer: B

Privacy laws prohibiting the cross-border flow of personally identifiable information may make it impossible to locate a data warehouse containing customer information in another country.

D4-Q197: Responsible for Information Classification

Question

The person responsible for ensuring that information is classified is the:

A. Security manager
B. Technology group
C. Data owner
D. Senior management

D4-Q197: Answer

Correct Answer: C — Data owner

The data owner is responsible for applying the proper classification to the data. The security manager applies protection; the technology group may have custody; senior management is responsible for the enterprise.

D4-Q198: Transmitting Personal Information

Question

Which is the MOST important when transmitting personal information across networks?

- A Encrypting the personal information
- B Obtaining consent to transfer personal information
- C Ensuring the privacy of the personal information
- D Ensuring effective change management

D4-Q198: Answer

Correct Answer: C

Privacy protection is necessary to ensure that the receiving party has the appropriate level of protection of personal data. Encryption is a partial answer; consent is not always required; change management is supportive.

D4-Q199: Excessive Workstation Images KRI

Question

An excessive number of standard workstation images can be categorized as a key risk indicator for:

A. Change management
B. Configuration management
C. IT operations management
D. Data management

D4-Q199: Answer

Correct Answer: B — Configuration management

An excessive number of unique workstation images indicates poor configuration management processes and insufficient attention to actual business requirements during image definition.

D4-Q200: Addressing Data Leakage

Question

Which BEST addresses the risk of data leakage?

A. Capacity planning procedures
B. File backup procedures
C. Acceptable use policies
D. Database integrity checks

D4-Q200: Answer

Correct Answer: C — Acceptable use policies

Acceptable use policies are an important control for preventing unauthorized disclosure of confidential information. Capacity planning and integrity checks do not address confidentiality; backup procedures are not the best data leakage control.

Exam Summary: 200 Hard Questions

Domain Coverage

- **Domain 1: Governance** — Q1–Q55 (55 questions)
- **Domain 2: IT Risk Assessment** — Q56–Q100 (45 questions)
- **Domain 3: Risk Response and Reporting** — Q101–Q165 (65 questions)
- **Domain 4: IT and Security** — Q166–Q200 (35 questions)

How to Use This Deck

Read each question, commit to an answer, then advance to the next slide to verify against the ISACA justification.

Key Takeaways Across Domains

Golden Rules from the QAE Manual

- Business management owns risk; senior management accepts it; the board is ultimately accountable
- Risk identification precedes assessment; you cannot protect what you do not know exists
- Residual risk = remaining risk after controls; acceptable risk = residual within tolerance
- BIA establishes RTO, RPO, MTD; risk assessment evaluates likelihood and impact
- Control types: preventive (stop), detective (find), corrective (fix), deterrent (discourage), compensating (alternate)
- KRIs predict risk; KPIs measure performance; KCIs measure control effectiveness
- Cost-benefit analysis justifies controls; when cost exceeds benefit, accept the risk

Final Advice

Exam Strategy

- Read the entire stem; look for **BEST**, **MOST**, **FIRST**
- Eliminate wrong choices, then choose the **business-focused** answer
- Understand the *why* behind each justification
- Practice scenario-based reasoning — application beats memorization

Good Luck on Your CRISC Exam!